E. Technology Vendors, Data Providers, and Networks

This section is intended for all stakeholders to provide input on questions as they relate to use cases and workflows that involve technology vendors, data providers, and networks. While we certainly want technology vendors, data providers, and networks to answer questions in this section (and in other sections) from their point of view, we also invite all stakeholders to provide their viewpoints on the technology vendor, data provider, and network use cases as appropriate.

About Selfiie

Executive Summary

Selfiie is revolutionizing healthcare data access by putting patients in control of their complete medical records. Our platform combines patient empowerment and agency over their medical records with enterprise-grade security, enabling secure data sharing that benefits patients, providers, payers, and researchers while maintaining the highest privacy standards.

Our Solution

Comprehensive Personal Health Records (PHR) *Selfiie creates your portable medical record accessible from your smartphone. We leverage patients' HIPAA right of access and the 21st Century Cures Act to retrieve complete records—both structured and unstructured—across the entire care continuum. Our informatics pipeline processes and enriches this data using industry standards (SNOMED, NDC, RxNorm, LOINC, ICD) to create a unified, computable research-grade health record for each patient. Additionally, our AI tools process each patient's medical record to generate a user-friendly health summary that gets updated with each additional data point.*

Market Reach & Partnerships

We contract directly with 22 regional and state Health Information Exchanges (HIEs), providing patient data access to over 130 million Americans today—covering more than 40% of the U.S. population. We also integrate with Carequality and TEFCA for additional comprehensive patient data access services. We are in the process of providing all Selfiie users with a Direct Secure Messaging address to further expand data access and secure communication services.

Identity Verification & Security *For the last 18 months we have identity-proofed all Selfiie users nationwide using CLEAR's IAL2 and AAL2 process, ensuring robust security and compliance.*

Advanced Privacy Architecture *Our exclusive TripleBlind privacy technology ensures patient health information (PHI) remains completely protected while still enabling valuable insights to be derived from individual or aggregated patient data. This encryption has been validated by HIPAA expert Dr. Brad Malin and advisor Deven McGraw, and has successfully withstood testing*

by MITRE and federal intelligence agencies. Unlike traditional approaches, our system allows data access without de-identification or data leaving secure firewalls—a true game-changer for healthcare data utilization.

Leadership & Expertise

Our founding team brings unparalleled experience to healthcare data innovation:

- ***Glenn Keet**: Founded Axolotl, the company that built the original commercial HIE industry*
- ***Ridhhiman Das (CTO)**: Invented HIPAA-level privacy protections as co-founder of TripleBlind*
- ***Anil Sethi**: Known as the "OG of the PHR" by CARIN's Ryan Howells, created Gliimpse (now Apple Health Records) and is bringing this vision to billions of Android users*

This proven leadership ensures our solutions are grounded in innovation while providing confidence in platform reliability and scalability.

Patient Empowerment & Use Cases

Patients can use Selfiie to:

- *Browse and manage their complete medical records*
- *Grant secure one-time or permanent access to healthcare providers and family members*
- *Donate data to research organizations like NIH or Red Cross*
- *Participate in our opt-in data marketplace, The TripleBlind Exchange, with full consent and compensation*

Monetization is always patient-controlled and consensual—we never de-identify and resell patient records without explicit permission.

Commitment to Health Equity

We will provide free Selfiie access to all Medicaid, Medicare, veteran, and active duty enrollees, ensuring underserved populations have equal access to their health data. This "digital twin" approach helps automate clinical trial matching, enables research data donation, and gives patients complete control over their health information.

Industry Collaboration & Open Source Initiative

*As **active CARIN Alliance members**, we support their RFI submission and "kill the clipboard" initiative. We plan to release a prototype in Q4 2025 and will open-source key technologies, including:*

- *Elements of our TripleBlind privacy IP*
- *MCP model-context-protocol APIs*
- *Custom MIRTH channels*
- *AI-ready architecture components*

This open-source approach accelerates industry adoption, reduces integration costs, and supports CMS's interoperability objectives while helping HIEs meet 21st Century Cures Act mandates.

Technical Innovation

***Selfiie's Patient Data Model (PDM)** is based on but surpasses FHIR in expressiveness and may be released to the public domain. Our **TripleBlind technology** eliminates traditional de-identification requirements, enabling secure, consented record access that preserves both privacy and data integrity. TripleBlind has over 25 patents for its approach and novel encryption methods.*

Policy Advocacy

We urge CMS to address critical industry challenges:

- ***Strengthen federal oversight** to address widespread noncompliance with Individual Access Services (IAS)*
- ***Mandate IAS response** from participating healthcare entities*
- ***Reform regulations** that prevent HIEs from fulfilling valid patient requests*
- ***Improve identity proofing standards** with more flexible verification options*

Business Model

Our transparent, patient-first approach includes:

- ***Free personal use** - patients never pay to access their own health data*
- ***Free sharing** with providers and family members*
- ***Transaction-based revenue** - we collect fees only when patients choose to participate in The Exchange*

- ***No data sales*** *- we never sell de-identified data without explicit patient consent*

This ethical approach ensures responsible data stewardship, builds trust across the healthcare ecosystem, and aligns with CMS's vision for patient empowerment and data transparency.

Selfiie is transforming healthcare through patient-controlled data access, advanced privacy protection, and collaborative innovation—creating a more connected, efficient, and equitable healthcare system for all.

1. Ecosystem

TD-1. What short term (in the next 2 years) and longer-term steps can CMS take to stimulate developer interest in building digital health products for Medicare beneficiaries and caregivers?

TD-1. To help developers build digital health product, CMS should provide ***online*** *developer toolkits with standardized FHIR APIs, synthetic longitudinal patient data, and reference Python test scripts working from test sandboxes, enabling rapid prototyping of AI-powered agents, voice avatars, and LLM-driven assistants, enabling developers to build and test MVPs in a single day.*

CMS could consolidate and make available a nationwide directory of providers. Significant innovation, automation and efficiency will follow.

For data access purposes by patients, it will be important that CMS does not require the patient to authenticate using portal credentials or other patient-known information. Rather, we implore that patients can be identity-proofed to IAL2 (or a lower but federally-approved level) enabling them to retrieve their data. CMS will stimulate more developer interest if patient apps can retrieve patient data without requiring the patient to authenticate directly with CMS (or any other payer) within the third party app. We refer to the need for application authentication as "portalitis" which is a proven significant inhibitor to patient adoption.

TD-2. Regarding CMS Data, to stimulate developer interest—

a. What additional data would be most valuable if made available through CMS APIs?

TD-2a. The most valuable data to add beyond traditional claims information will be complete clinical/health data as well as SDOH data. Examples of additional valuable CMS data may include: longitudinal health data (particularly medications, labs, diagnoses, problems, vitals); longitudinal insurance coverage data, social determinants of health (including indications of joblessness, poverty, homelessness, transportation challenges, etc.), and real-time encounter and claims data accessible via FHIR bulk APIs to enable advanced predictive analytics and AI-

driven insights. Additionally, it would be highly beneficial if CMS would maintain a fully up-to-date and accurate NPI database, as current discrepancies and delays in provider and entity NPI updates hinder reliable data integration and interoperability.

b. What data sources are most valuable alongside the data available through the Blue Button 2.0 API?

TD-2b. The most valuable data sources to complement Blue Button 2.0 API are EHR data—such as medications, labs, diagnoses, procedures, vitals, and immunizations—plus social determinants and care team. To overcome inconsistent FHIR implementations, CMS should mandate a small, core set of standardized data elements across all FHIR APIs, focusing on about 10 essential fields in each of 17 key clinical categories of a CCD. Or USCDI v2, 3 or 4 if possible. This would create a clear, manageable standard, improve interoperability, and ensure reliable integration of Blue Button data with other critical clinical sources. If the Blue Button produced a full CCDA document with clinical and health plan data it could easily be loaded into nearly any EHR or PHR to enhance the patient's medical record.

c. What obstacles prevent accessing these data sources today?

TD-2c. Presumably the biggest obstacle to providing this data would be CMS' lack of collecting these data points. However, if CMS does have access to this clinical data, CMS's FHIR implementation remains at Level 3 maturity, lacking the advanced workflows and comprehensive data elements of Levels 4 and 5, which restricts support for complex use cases and AI-driven health solutions. Additional barriers include heterogeneity in FHIR implementations across vendors, limited API capabilities for unstructured data (like scanned documents), and fragmented, non-standardized consent management tools that impede seamless, authorized data flow.

d. What other APIs should CMS and ASTP/ONC consider including in program policies to unleash innovation and support patients and providers?

TD-2d. CMS and ASTP/ONC should require expanded FHIR API sets, including real-time event notifications (such as admission, discharge, and transfer alerts), FHIR Bulk Data Export for population-level analytics, and APIs that support AI/ML model integration for advanced use cases like risk stratification and conversational patient engagement. Standardizing APIs for payer-to-payer data exchange (in FHIR, not X12), NPI provider directories would further enhance interoperability and innovation across the healthcare ecosystem.

2. Digital Identity

TD-3. Regarding digital identity implementation:

TD-3. As mentioned previously, it would be most beneficial for CMS to utilize remote identity proofing for authentication and not rely on the patient authenticating directly using credentials with CMS or via the password methods at login.gov. Other federal and nationwide data access systems utilize identity proofing. Patients have "portalitis" and do not recall their USERID/password combinations. Moreover, patients in third party applications can't rely on their browser remembering their password or their password manager knowing it when in an alternate app from the website.

TEFCA uses IAL2 to enable patients' self-service requests for data as the necessary authentication. Our experience with IAL2 is that 10 to 12% of patients will fail (due to ID issues or corroboration issues). While we mentioned earlier that a theoretical IAL1.8 standard may be more suitable (and would perhaps enable just a 2% or lower fail rate), some form of patient identity will always be better than site credentials. When a patient is unable to pass IAL1.8 or IAL2, CMS can leverage pharmacies' existing in-person identity verification workflows for prescriptions to address these failures in remote scenarios. Pharmacies already validate government-issued IDs (e.g., driver's licenses, passports) under DEA and state regulations making them ideal for offline identity proofing. Allowing patients who fail remote IAL2 checks to visit a CMS-certified pharmacy for in-person verification significantly reduces the burden on the patient. Pharmacies would validate IDs against DEA/state standards (e.g., 8 C.F.R. § 274a.2) and update the patient's verification status in CMS systems (e.g., via NCPDP DataQ). Integrate pharmacies into CMS's identity management framework as trusted "IAL2 exception" validators, similar to HHS's XMS exception process.

Use pharmacies enrolled in the Medicare Transaction Facilitator (MTF) as verification hubs. MTF's reliance on NCPDP DataQ (Section 2, CMS MTF FAQ) enables real-time validation of pharmacy credentials and patient interactions. Align with DEA's EPCS guidelines, which permit institutional practitioners (e.g., pharmacies) to conduct identity proofing (DEA-DC-9 R1).

The benefits include:

Equity: Addresses IAL2's current corroboration challenges with some phone plans by providing a physical fallback.

Security: Pharmacies' existing anti-diversion protocols (e.g., DEA Manual §1301.22) ensure rigorous ID checks, reducing fraud risk.

Efficiency: Reuses established workflows, minimizing new burdens on pharmacies or patients.

An example: A patient failing IAL2 online walks into a local MTF-enrolled pharmacy. The pharmacist verifies their ID per DEA/Florida HB 21 standards, confirms their identity. Apps and vendors can then use this identity verification to provide follow-on services.

Separately, but along the same lines, CMS could ensure that the post-office in person validations covered by login.gov could be extended to all Kantara-initiative certified identity service providers. In that way, patients having trouble getting identity-proofed for CMS or any other healthcare platform could go to their local post office to resolve it.

a. What are the challenges and benefits?

TD-3a. Identity Assurance Level 2 (IAL2), as defined by NIST, should be revisited to assure it is not too high a standard for for patients to successfully pass identification. While this level of assurance is intended to protect sensitive information, it creates a barrier for some patients trying to access their medical records, especially "in the wild"—that is, outside controlled environments or without institutional support.

Another benefit is how digital identity will thwart anti-competitive practices that are rampant in the industry. EHRs requiring direct authentication with their portal (again, inducing "portalitis") is mainly a hidden way for those EHRs to build a moat to their data as well as boost their business models (EHRs requiring portal authentication are typically generating revenue by increasing user counts of the portal). We believe there are reinstated executive orders targeting this kind of anti-competitive practice (e.g. EO 13813), and they should be enforced.

b. How would requiring digital identity credentials (for example, CLEAR, Login.gov, ID.me, other NIST 800-63-3 IAL2/AAL2 CSPs) impact cybersecurity and data exchange?

TD-3b.
Better adherence than userid/password. *Requiring patient authentication in a third party application will have a high failure and abandonment rate. Users do not remember their credentials, their browser password solutions won't work in third party applications, nor will their password managers automatically fill in in a different application.*

Demographic Matching Improvements. *For IAL2 and most other remote identity standards, patients are required to provide up-to-date, high-quality identity documents. That said, address mismatches are still common—up to 15% of consumers have outdated or inconsistent address information on their ID or in healthcare systems, which can prevent successful demographic matching. Selfiie has successfully addressed this challenge with the HIEs it queries for patient data by working with them to increase the matching value of* ***verified phone number*** *and* ***email address*** *fields, while lowering the matching value of home address fields. We recommend CMS do the same for probabilistic patient matching fields. Demographic matching* ***works very well*** *when tuned correctly, and there are no better identifiers in healthcare than a patient's mobile number and email address.*

Additionally, once a patient has been identity-proofed to IAL2, they should be allowed to add their other past or current addresses for medical records look up. Even though these addresses are not the "verified addresses" as scraped off their government ID, the patient has been proven to be who they say they are, and their additions of alternate home addresses should be accepted and used. Alternatively, using a USPS API to get known valid alternate addresses for an IAL2 patient should be acceptable. This will ensure the highest level of demographic matching.

***Prepaid Plans and Underserved Populations**. Consumers using prepaid mobile plans or those on family cell phone plans can face additional hurdles with respect to IAL2 corroborations. These individuals may lack the necessary documentation or have difficulty passing stringent checks, making it nearly impossible for them to meet IAL2 requirements. The standard's reliance on strong evidence and sometimes biometric verification disproportionately impacts these under privileged and under represented groups, effectively locking them out of digital health access. Consider supporting an IAL1.8 standard that will still ensure a high degree of certainty for any patient while not keeping approximately 10 - 12% unable to use it. See next section below.*

***A task force to take a position on AL1.8**, which is a hypothetical slight lessenging of IAL2 frameworks, and could address IAL2's accessibility barriers by balancing verification rigor with practical flexibility for the underprivileged. While IAL1.8 isn't explicitly defined in NIST standards, extrapolating from FHIR's IDIAL1.5/1.6 tiers , it might incorporate the following solutions:*

***1. Reduced Document Burden**. IAL1.8 could accept alternative evidence like medical record numbers, insurance cards, or digital identifiers instead of strict government-issued IDs. This would help prepaid plan users or those without traditional documentation, who often fail IAL2's rigid evidence requirements.*

***2. Flexible Address Verification**. By allowing temporary addresses (e.g., shelters) or partial matches (e.g., zip codes only), IAL1.8 would mitigate the 15% failure rate often caused by exact address matching in corroborations. Notifications could shift from postal mail to SMS/email, aligning with mobile-centric populations.*

***4. Tiered Evidence Combinations**. A structure requiring two "Fair" evidence types (e.g., prepaid phone number + clinic-issued ID) instead of IAL2's "Strong + two Fair" rule would lower abandonment rates by accommodating non-traditional users.*

***5. Progressive Escalation**. IAL1.8 could allow initial access with basic verification (e.g., email + phone control), then prompt for additional evidence only when accessing sensitive records. This contrasts with IAL2's all-or-nothing approach.*

While IAL1.8 wouldn't match IAL2's fraud prevention, its hybrid model—combining IAL1's accessibility with incremental proofing—could resolve the key issues of exclusion, technical

complexity, and high failure rates inherent to IAL2 implementations. ***Regardless, we still strongly believe IAL1.8 or IAL2 is significantly better than patients being required to supply userid/password credentials with TFA.***

c. What impact would mandatory use of the OpenID Connect identity protocol have?

TD-3c. We support OpenID because:

Granular Consent and Authorization*: Empowers patients to control who accesses their data, enhancing privacy and trust.*

Role-Based Access Control (RBAC)*: Limits data exposure by ensuring users only see information relevant to their roles, reducing risk of unauthorized access.*

Data Encryption*: Safeguards patient information during transmission and storage, minimizing the risk of data breaches.*

Auditability and Transparency*: Enables monitoring and detection of unauthorized access, supporting accountability and rapid response to incidents.*

3. Technical Standards and Certification

TD-4. How can CMS better encourage use of open, standards-based, publicly available APIs over proprietary APIs?

TD-4. CMS should be flexible by allowing FHIR-based APIs for prior authorization instead of the legacy X12 278 standard, signaling a preference for modern, open APIs and reducing regulatory barriers to their adoption.

CMS could offer financial incentives or grants, as recommended by informatics experts, to support the transition to open APIs—especially for smaller or resource-limited organizations.

TD-5. How could a nationwide provider directory of FHIR endpoints improve access to health information for patients, providers, and payers? Who should publish such a directory, and should users bear a cost?

TD-5. ***Simplified Data Exchange****: A national directory makes it easy to discover and connect to the correct FHIR endpoints for any of the applications supporting patients, providers or payers, reducing the complexity and time required for discovering sources of patient data. This is especially valuable for patients moving between care settings or payers, and for providers coordinating care across organizations. Think of this as a simple HTTP request that always succeeds in connecting with the API's of a provider or payer.*

***Support for Regulatory Compliance**: Such a directory helps organizations meet CMS and ONC interoperability requirements, including public access to provider directory information via standardized APIs. In summary, a nationwide FHIR endpoint directory—centrally managed by CMS and **freely** accessible—would greatly improve access, efficiency, and innovation in health information exchange for all stakeholders in the healthcare system. These API's, combined with synthetic data sets, reference Python implementations, etc., will dramatically accelerate vendor development of solutions.*

Making access to the provider directory free will ensure it is utilized, therefore enabling the benefits that are sought to be achieved.

TD-6. What unique interoperability functions does TEFCA perform?

While most interoperability functions of TEFCA are similar to that of Carequality, the difference is that TEFCA is public-private versus a commercial venture. A key feature is the Common Agreement participants sign because it provides a unified, federally recognized set of rules and technical standards for health information exchange, greatly reducing the burden on networks that previously had to negotiate multiple, inconsistent agreements. A challenge is that TEFCA is voluntary because there are structural disincentives for most institutions to share information with other institutions, and there are documented cases of patient access being thwarted by making the requirements threshold overly burdensome trying to meet the wishes of industry partiicpants. Other than IAS and related language, patient access, while mandated, is typically refused as of now by network participants.

a. What existing alternatives should be considered?

TD-6a. While not an alternative, the Direct protocol is the most widely adopted interoperability standard in the U.S., embedded in nearly all certified EHR and more importantly, practice management systems (PMS). Direct is the "push" technology used in point to point, like secure email. These are frequently used at clinics and physician private offices, which allows secure, HIPAA-compliant messaging for referrals, care transitions, and notifications. Its broad integration and ease of use make it critical for everyday clinical workflows, supporting more EHR and practice management integration than any other protocol and facilitating efficient, scalable communication across the healthcare system.

TEFCA is the "pull" technology, enabling requests/queries. Other nationwide query networks exists, such as Carequality. These two are very aligned, with one being government directed public/private (TEFCA) and the other being industry driven (Carequality, Commonwell, eHealth Exchange).

It would be best if the industry query exchanges were also to survive rather than being put out of business by TEFCA, with consolidation of these likely. Over time different use cases will emerge that are suited better to the public-private exchange or the industry exchange.

b. Are there redundant standards, protocols or channels or both that should be consolidated?

TD-6b. Yes, there are redundant and overlapping standards, protocols, and channels. Varied Technical Standards, including a mix of HL7 v2, C-CDA, FHIR, and proprietary APIs, create interoperability gaps.

TD-7. To what degree has USCDI improved interoperability and exchange and what are its limitations?

USCDI has improved interoperability by standardizing key data elements across EHRs, and supporting major federal initiatives like TEFCA and CMS rules. But adoption is uneven, with large health systems and EHR vendors leading the way while smaller providers and specialty settings face technical and financial barriers.

a. Does it contain the full extent of data elements you need?

TD-7a. USCDI is a regulated, standardized health data set mandated for nationwide interoperability, but it does not encompass the full set of information which patients are entitled to under their HIPAA right of access. While USCDI includes core data classes such as medications, laboratory results, clinical notes, and some diagnostic imaging data, it does not require the inclusion of all imaging files, full payment and claims data, or the entirety of doctors' notes, pathology, and radiology reports. And yet, under HIPAA, all of this missing information is the right of the patient to attain a copy of. For example, only certain types of clinical notes are mandated, and imaging data is represented primarily through reports rather than the actual images or all associated documentation. Payment and claims data are not comprehensively included, and narrative or specialty notes may be omitted depending on the USCDI version. USCDI v4 builds on previous versions and adds more fields, but ultimately ALL healthcare and related data held by a covered entity should be shared with a requesting patient.

b. If not, is it because of limitations in the definition of the USCDI format or the way it is utilized?

TD-7b. Gaps in USCDI coverage arise from both its foundational design and practical implementation: the standard prioritizes broadly applicable data elements, often excluding niche or emerging types, and its annual update cycle lags behind rapidly evolving real-world needs like those seen during public health emergencies.

c. If so, would adding more data elements to USCDI add value or create scoping challenges? How could such challenges be addressed?

TD-7c. Expanding USCDI by adding more data elements could enhance clinical utility—such as by including Date of Onset for chronic disease tracking—and USCDI+ extensions enable domain-specific customization (like CancerX for oncology) without overloading the core dataset; however, these benefits must be weighed against the risk of resource strain for smaller vendors, who may struggle with costly upgrades, and the potential for fragmentation if the dataset becomes too broad. To address these challenges, solutions such as modular certification—allowing systems to certify only for relevant subsets of USCDI—and phased adoption aligned with the Standards Version Advancement Process (SVAP) can help maintain focus on interoperability while supporting incremental growth.

d. Given improvements in language models, would you prefer a non-proprietary but less structured format that might improve data coverage even if it requires more processing by the receiver?

TD-7d. While large language models (LLMs) are increasingly effective at extracting structured data from unstructured text, structured formats remain essential for ensuring consistency in decision support, quality reporting, and regulatory compliance, as well as minimizing processing burdens for data receivers. A hybrid approach—using LLMs to enrich structured USCDI data (such as extracting social determinants of health from clinician notes) and adopting FHIR alongside LLM tools—offers a balanced solution that combines flexibility with standardization. Data that is already structured should always be offered as such. But the USCDI should be expanded to include unstructured documents so LLMs can be trained on this valuable data resource. In our experience, depending on the therapeutic area or illness, less than 10% of the clinical information needed to operationalize an encounter between patient and physician, is available using FHIR, the bulk of nuanced clinical information is found in the (for example) findings paragraph on a pathology or radiology report which generally is not carried in FHIR.

TD-8. What are the most effective certification criteria and standards under the ONC Health IT Certification Program?

TD-8. The least effective certification program has been for EHRs. While it moved the ball with meaningful use and standardizations of collected data, it negatively affected the fidelity of the data captured. Most EHRs moved to templates with checkboxes and drop down lists to ensure their provider users met all the requirements. Drop down lists, no matter how lengthy, do not usually capture exactly what the doctor is considering. Given that the computer can easily remind a physician if they forgot to record something in their encounter (e.g. did they ask about smoking cessation for a current smoker) it doesn't behoove the provider to have the EHR to structure their input. In healthcare data, the most valuable data is the narrative, and restricting that to templated paragraphs or drop down lists hurts the fidelity of the medical record.

The interoperability requirements were very effective. Virtually every commercial EHR supports production and exchange of CCDA documents, and support integration with Direct Secure Messaging.

Separately, the HITECH Act spurred statewide HIEs; however, it didn't mandate suffiicent features and functions, and several statewide HIEs went bust due to poor business models, insufficient interoperability and bad choices of platforms. A key idea of the NHIN (and susbsequent iterations, including TEFCA) was to be a network of networks connecting regional and statewide HIEs, ***not replacing them****. Most healthcare is local, and there needs to be support for regional and statewide HIEs, who lessen the burden of traffic on nationwide networks. An emerging model to support these regional HIEs are called Health Data Utilities, or HDUs. They are guaranteed to be useful because they mandate certain use cases, and guaranteed to be sustaining because like utilities their infrastructure is tax subsidized.*

TD-9. Regarding certification of health IT:

a. What are the benefits of redefining certification to prioritize API-enabled capabilities over software functionality?

TD-9a. Require FHIR-based APIs and Direct protocol as the default for certified health IT, ensuring real-time, standards-based data exchange across systems. Tie certification and reimbursement to API-enabled interoperability.

b. What would be the drawbacks?

TD-9b. The hard part for developers is where to start. CMS should provide technical assistance, Quickstart kits, sandboxes, test data and funding for small vendors and providers to implement and secure APIs—without which, developers and vendors don't know where to start because clinical informatics is an extremely nuanced and difficult space to master.

c. How could ASTP/ONC revise health IT certification criteria to require APIs to consistently support exchanging data from all aspects of the patient's chart (for example, faxed records, free text, discrete data)?

TD-9c. Update certification to require APIs to support FHIR resources for all chart domains, including attachments for scanned/faxed documents and structured/unstructured data. As mentioned previously, the free text carried in a variety of reports in a variety of document types (fax, PDF, Word, etc.) is the most useful data for advanced treatment, matching to clinical trials, etc. This free text and documents need to be supported in the APIs.

d. What policy changes could CMS make so providers are motivated to respond to API-based data requests with best possible coverage and quality of data?

TD-9d. Develop API usage dashboards and quality metrics for API responses, and integrate automated completeness checks. Create publicly available scoring of coverage, quality and responsiveness by providers – who are typically not motivated to respond. Link CMS payment incentives and public reporting to API response rates and data quality, and penalize non-compliance to drive provider engagement.

e. How could EHRs capable of bulk data transfer be used to reduce the burden on providers for reporting quality performance data to CMS? What capabilities are needed to show benefit? What concerns are there with this approach?

TD-9e. Mandate FHIR Bulk Data Access (Flat FHIR) support in certified EHRs, with patient matching (tokenization) and longitudinal data aggregation capabilities. Allow bulk data submission for quality programs, reduce manual reporting requirements, and establish clear privacy and security standards for bulk transfers. One of Selfiie's advisors, Deven McGraw, while working with our team at Ciitizen created a publicly available report card of how long providers take to respond to medical record access requests. It had a profound influence that improved response times, sometimes shortened from 30 days to three days.

TD-10. For EHR and other developers subject to the ONC Health IT Certification Program, what further steps should ASTP/ONC consider to implement the 21st Century Cures Act's API condition of certification (42 U.S.C. 300jj-11(c)(5)(D)(iv)) that requires a developer's APIs to allow health information to be accessed, exchanged, and used without special effort, including providing access to all data elements of a patient's electronic health record to the extent permissible under applicable privacy laws?

TD-10. The 21st Century Cures Act's API condition of certification is robust in its regulatory language, requiring certified health IT developers to provide APIs that enable access to all permissible data elements in a patient's electronic health record "without special effort". However, the primary shortcoming lies not in the regulations themselves but in inconsistent follow-up and enforcement. While ONC and ASTP have established punitive measures—such as decertification, certification bans, fines and corrective action plans for non-compliance—enforcement actions remain infrequent and reactive, often triggered only by complaints or direct review rather than proactive oversight. This has allowed some certified developers to impose artificial barriers, delay updates, or restrict access in ways that undermine the spirit of the law. For the regulations to achieve their intended impact, ONC and ASTP must move from a complaint-driven model to regular, proactive audits and public reporting of compliance, ensuring that certified APIs deliver the full, effortless access and exchange mandated by the Cures Act.

*Importantly, one concrete step would be to **shield covered entities that in good faith** share data with requesting patients are protected from the harsh breach notification rules when, by no*

negligence of the covered entity, the wrong patient receives data. These protections already exist for delivering patient data to the wrong provider, they need to be extended to cover them for mistakes regarding patients. Perhaps more than anything this will speed compliance with patient access directives.

TD-11. As of January 1, 2024, many health IT developers with products certified through the ONC Health IT Certification Program are required to include the capability to perform an electronic health information export or "EHI export" for a single patient as well as for patient populations (45 CFR 170.315(b)(10)). Such health IT developers are also required to publicly describe the format of the EHI export. Notably, how EHI export was accomplished was left entirely to the health IT developer. Now that this capability has been in production for over a year, CMS and ASTP/ONC seek input on the following:

a. Should this capability be revised to specify standardized API requirements for EHI export?

TD-11a. ***Standardized API Requirements for EHI Export****: CMS and ASTP/ONC should revise EHI export requirements to mandate standardized, FHIR-based APIs for both single-patient and bulk exports, ensuring uniformity and interoperability across vendors. In parallel, the Direct protocol should be explicitly supported as a standards-based, scalable, and secure transport option for pushing EHI to and from trusted partners, leveraging its widespread adoption and integration within certified EHRs. Both FHIR and Direct support interchange through a CCD document. But, the operative word is still* ***enforcement****.*

b. Are there specific workflow aspects that could be improved?

TD-11b. ***Workflow Improvements****: EHI export workflows should be streamlined by embedding Direct export and Direct Secure Messaging functionality into patient portals and apps, enabling automated notifications, status updates, and seamless push of records to known recipients. Direct's authenticated, encrypted messaging ensures secure, point-to-point transfer of both structured and unstructured data. Like fax, it is supported everywhere. Based on certificate-secured email, it's simple to implement.*

c. Should CMS consider policy changes to support this capability's use?

TD-11c. ***Policy Support****: CMS should incentivize and, where appropriate, require adoption of both standardized APIs and Direct protocol for EHI export, tying compliance to reimbursement and quality reporting. Policy should penalize non-compliance, ensuring that all certified health IT delivers consistent, secure, and user-friendly EHI export capabilities.*

4. Data Exchange

TD-12. Should CMS endorse non-CMS data sources and networks, and if so, what criteria or metrics should CMS consider?

TD-12. A comprehensive health data ecosystem should incorporate: emergency information from sources like the Clinical Emergency Data Registry (CEDR), which aggregates real-time data from emergency departments. Disease registries such as the PRIME Registry and other Qualified Clinical Data Registries (QCDRs) extract EHR data from primary care and specialty practices nationwide. Claims databases, including All-Payer Claims Databases (APCDs).

Together, CMS should consider endorsing such data sets—emergency registries, public health reporting systems, disease registries, claims databases, quality measurement tools, deidentified research datasets, and Medicare plan directories—form the backbone of modern health information exchange.

However, Selfiie is not in support of de-identified data sets. The de-identification process is time consuming and expensive, and even certified de-identified data sets can be merged with other data and be quickly re-identified. Worse, the de-identification process harms the fidelity of the data for the intended research purposes. Rather, full-fidelity data needs to be able to be accessed in a secure, HIPAA compliant manner, with solutions such as Selfiie's TripleBlind. This is not a shameless plug, just an awareness campaign that de-identification is old, meager technology that is collectively costing the healthcare data markets many billions of dollars. If the federal government wishes to build a federated data lake, privacy preserving technology deployed at the site of the data is the logical way to go. And consider removing the carve out in HIPAA for de-identified data use so as to protect patient data.

TD-13. What new opportunities and advancements could emerge with APIs providing access to the entirety of a patient's electronic health information (EHI)?

The founders and team at Selfiie have considerable experience and history going back for decades in the construction of what is typically called a patient's PHR (personal health record or PHA, personal health application). We believe that many patients will soon carry a portable health summary on their smart phone. Under their control, with data access also under their control. Currently, due to the fragmented landscape and multiple portals and end points, there is no single API providing access to the entirety of a patient's electronic health information. Having this would unlock opportunities for comprehensive, real-time data sharing that can enhance clinical decision-making, patient engagement, and innovative app development. In 2025 Selfiie plans to release into the public space our recommendation for a single API that can access the entirety of a patient's complete health record.

a. What are the primary obstacles to this?

TD-13a. Primary obstacles include inconsistent API performance, hurdles with adoption, variable data completeness beyond USCDI, and technical challenges integrating unstructured or

proprietary data formats. While these are obstacles, Selfiie's plan to release a publicly available API may lower or remove them altogether.

b. What are the primary tradeoffs between USCDI and full EHI, especially (printed page 21040) given more flexible data processing capabilities today?

TD-13b. The tradeoff between USCDI and full EHI lies in balancing standardized, manageable data sets against the richer but more complex full EHI; advances in flexible data processing and AI can help bridge this gap but require robust metadata and provenance to maintain data integrity and usability. To maximize value, CMS and ONC should mandate standardized, performant FHIR-based APIs for full EHI export, support workflows that handle both structured and unstructured data, and incentivize adoption through policy levers tied to data completeness and quality. Of key importance is making available de-identified or synthetic data to train LLMs on the full complement of EHI.

TD-14. Regarding networks' use of FHIR APIs:

a. How many endpoints is your network connected to for patient data sharing? What types, categories, geographies of endpoints do you cover? Are they searchable by National Provider Identifier (NPI) or organizational ID?

TD-14a. Selfiie operates a Cures Gateway network of 22 contracted regional and state HIEs representing a population of 130M patients. We continue to work to add additional HIEs. Given the lack of responsiveness by participants of TEFCA to IAS and of Carequality to Patient Request, this makes Selfiie the operator of the largest and most robust self-service patient access network in the US.

Selfiie requires patients to be identity-proofed to IAL2 prior to submitting a demographic match inquiry to these HIEs. Selfiie also allows for third party personal health applications that have applied and been vetted to also use our Cures Gateway network to enable patients to request and retrieve their data from the HIEs.

While HIEs are not homogenous, almost all respond with inpatient and outpatient medical records. These typically include labs, imaging reports, and various encounter reports (often dictated/transcribed or typed entry) including chart note, progress note, discharge summary, pre-operative history and physical report, pathology report, as well as medications and immunizations. Most often an on-demand CCD is created by the HIE, and additional transactions are launched for documents not contained in the CCD.

Selfiie has determined that the HIE data is far superior to getting data from nationwide networks, both in quality but also in control. It is straightforward for Selfiie to work with the 22 HIEs to ensure we get a complete record returned, that we ask for and get 5 or 7 years of

history, etc. With nationwide networks we have no individual relationship with the myriad potentially responding participants, and therefore no opportunity to know we are getting what we want or need.

Note that Selfiie is also connected to TEFCA through our QHIN MedAllies, and to Carequality through our onramp.

b. How are these connections established (for example, FHIR (g)(10) endpoints, TEFCA/Integrating the Health Enterprise (IHE) XCA, or proprietary APIs)?

TD-14b Selfiie works with the HIEs to use protocols they can quickly implement and support. Most choose to use IHE protocols, but more recently FHIR is the most common.

c. Do you interconnect with other networks? Under what frameworks (for example, TEFCA, private agreements)?

TD-14c. As mentioned above, we do connect to TEFCA and Carequality, but most of our data under the Individual Access purpose of use comes from our private agreement connections to HIEs.

TD-15. Regarding bulk FHIR APIs:

a. How would increased use of bulk FHIR improve use cases and data flow?

TD-15a. Bulk FHIR APIs enable efficient population-level data retrieval for analytics, risk stratification, and AI model training, but at a cost. Unless the data is de-identified, it is dangerous to enable its access and transfer, even to covered-entity partners under BAAs. De-identifying it, and getting an expert opinion on that data set is expensive. And there is no way to ensure the data doesn't end up on a marketplace with no attribution to its source. Exceptions to this rule would be HIEs whose job it is to aggregate, store and protect PHI for certain use cases (however there is no need for HIEs to migrate their data feeds with hospital and lab systems away from HL7 real-time feeds and switch to bulk FHIR APIs, as there would be no benefit).

b. What are the potential disadvantages of their use?

TD-15b. Disadvantages include governance challenges over large-scale data sharing and security risks requiring strong encryption and audit. They create additional silos of data. Most importantly, it isn't clear there is proper individual patient consent for the use of their data in these bulk exchanges, nor is it guaranteed it is masked or blinded. It would be significantly better for holders of large quantities of patient data to be able to respond in place to algorithms as opposed to having to ship data around, particularly if they can guarantee that no PHI is leaked. This is exactly what Selfiie's TripleBlind Exchange enables - access to full fidelity medical records without exposing or returning PHI to the requester. The data holder retains full control of their

data asset and can allow whomever they want to be able to interrogate their data knowing they are HIPAA and GDPR compliant. We feel the time for de-identification of data is in the past, as new technologies have leapfrogged this to save time, money and better protect patient data.

TD-16. What are the tradeoffs of maintaining point-to-point models vs. shared network infrastructure?

TD-16 There are good use cases for both point to point and shared network infrastructure. Point to point works well, for example, when you know exactly who you want to connect with or where you want to request data, whereas a shared infrastructure query is better for "search everywhere".

The Direct Project works well for point to point secure communications between providers, and has been extended to include patients. As such, this enables secure communications across something as easily understood as email. Direct has a directory of endpoints (providers and/or their EHRs), and all certified EHRs can ingest certain payloads. Selfiie incorporates a Direct address for every patient, and this allows a patient to securely send their provider new data, or even automatically generate and send a filled-out clipboard rather than yet again putting pen to paper. Patients can securely send their data to each other, like an elderly mother to her daughter who is in charge of her care.

However, pinging hundreds of thousands of Direct endpoints is not suitable for records discovery work. Shared infrastructure, particularly where a record locator service is utilized, makes that discovery fast and efficient.

As noted later in this response in TD-17, Selfiie does not suggest a nationwide shared network infrastructure should replace existing HIE data sharing networks. HIEs work well, add value, and carry the majority of the load of health information exchange. The shared network should enable HIE to HIE connectivity, but should not be considering handling any "last mile" connectivity. Regional HIEs need to survive and thrive to obtain the best of all worlds with respect to data access and sharing.

a. Do current rules encourage scalable network participation?

TD-16a. Point-to-point models under certain use cases hinder scalability; shared infrastructures supporting reciprocal access and API unification better serve AI and multi-stakeholder ecosystems.

b. What changes would improve alignment (for example, API unification, reciprocal access)?

TD-16b. Current rules should incentivize participation through streamlined certification and clear data sharing expectations.

TD-17. Given operational costs, what role should CMS or ASTP/ONC or both have in ensuring viability of healthcare data sharing networks, including enough supply and demand, that results in usage and outcomes?

TD-17. We highly recommend CMS, and more specifically state Medicaid agencies, support and work with their state and regional HIEs. Most healthcare is local, and these HIEs support the majority of the traffic. There is no point in trying to move that traffic to a different nationwide network. Keeping regional and state HIEs healthy and functional will significantly reduce the challenges required for that traffic and support to be handled at a nationwide level. This will keep operational costs down.

It is the outlier user case where patient data is not in the regional or state HIE - a patient has moved, a patient is seeking tertiary or quaternary care outside their region, etc. These are very important use cases, but likely represent 2% of traffic.

On the supply side, however, there is no good reason why participants in nationwide networks such as TEFCA or Carequality would participate in the "treatment" purpose of use but not for others, particularly individual access. Mandates for supporting a minimum set of purposes of use must be stated and enforced.

5. Compliance

TD-18. Information blocking:

a. Could you, as a technology vendor, provide examples for the types of practices you have experienced that may constitute information blocking. Please include both situations of non-responsiveness as well as situations that may cause a failure or unusable response?

TD-18a. We have seen HIEs contend they need not respond to a patient request for data since they were set up to work only with providers. That said, these same HIEs are doing electronic transactions supporting life insurance use cases and others that show they could support outside transactions. In general, I believe any HIE can support patient requests, particularly those situations where the third party application is handling first line support with the patient.

A different example is that Epic is requiring an additional step for individual access data requests from their Epic NEXUS QHIN, where the patient must authenticate with their MyChart app. Many patients will fail this additional step because their password managers or browser passkey features will not recognize the third party app and not supply their credentials. Patients won't remember, and will likely disengage at high rates. This additional hurdle could be considered info blocking. Part of the whole benefit of IAS is to avoid "portalitis", yet Epic is pushing people back there. We feel this is due to their business model, where they get recompensed by their

clients for the number of patients on the portal. So only patients who have access to MyChart can retrieve their medical records housed in Epic to add them to their other medical records.

Health plans also require patients to authenticate through their portal to pull data. Why have a standard for identity proofing if they are just going to be thwarted by having to recall their userid/password combination at each of their carriers? In addition to providers, payers and pharmacies should be required to respond to valid IAS requests with patients authenticated to IAL2 (or IAL1.8) and no other requirements, otherwise they should be treated like info blockers and suffer the consequences.

b. What additional policies could ASTP/ONC and CMS implement to further discourage healthcare providers from engaging in information blocking practices?

TD-18b. Policies should include automated compliance monitoring, mandatory transparency reports, and enforceable penalties. Practices should also be ***encouraged to participate in their regional or statewide HIE****, ensuring the HIE can respond to individual access requests for them. In that way they don't necessarily have to build, maintain or support specific APIs if they are connected to their regional HIE.*

CMS could also use previously used methods to encourage participation (carrot/stick). Pay higher fees or withhold payments based on participation.

CMS should make it clear that ***BAAs that prohibit*** *a receiving covered entity from further sharing data with patients are in violation of information blocking and can lead to fines. In other words, if a health system shares data with an HIE or HDU, that HIE and HDU must be able to respond to valid requests from patients for their data and include any data they hold for that patient, regardless of source.*

CMS should continue to remove or tighten exceptions to info blocking. Entities have had nine years now with the 21st Century Cures Act verbiage and legislation, and several years with enforcement. It should be a very high bar to avoid valid patient requests for their data.

We think it was a mistake to allow Epic, Oracle and any other EHR vendors from applying for and obtaining QHIN status. This has simply taken their EHR wars to a new platform, which will encourage tribalism and proprietary behaviors which will lead to information blocking. The cow may have left the barn now, but if there is some way to retroactively force EHR vendors to be participants instead of QHINs that would be best.

c. Are there specific categories of healthcare actors covered under the definition of information blocking in section 3022(a)(1) of the Public Health Service Act (PHSA) that lack information blocking disincentives?

TD-18c. Extending information blocking regulations to all healthcare actors and clarifying definitions around AI and digital tools will close enforcement gaps. It seems the disincentives only apply to those actors that participate in Medicare; we see no reason that this can't apply across all healthcare actors. As a notable example, pharmacies have no disincentives.

TD-19. Regarding price transparency implementation:

a. What are current shortcomings in content, format, delivery, and timeliness?

TD-19a. Price transparency suffers from inconsistent FHIR implementation, outdated pricing data, and poor integration with care navigation apps. And while we applaud efforts by SureScripts to provide real time pharmacy benefit information, they charge for this service and limit it to e-prescribing use cases. Patients should be able to look up information based on their medical records that they have aggregated using IAS. We are also participating with CARIN and their partner CVS in RTPBC early adopter/proof of concept, it would be better if this didn't have to be accomplished chain pharmacy by chain pharmacy.

b. Which workflows would benefit most from functional price transparency?

TD-19b. Pre-visit cost estimation and billing reconciliation workflows would benefit most.

c. What improvements would be most valuable for patients, providers, or payers, including CMS?

TD-19c. Real-time, standardized, and granular price data accessible via APIs would aid all stakeholders, especially when integrated with AI-driven care recommendations.

d. What would further motivate solution development?

TD-19d. Incentivizing developers through grants and incorporating price transparency into provider quality metrics would motivate innovation.